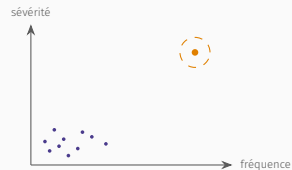


Risque opérationnel et résilience

Chapitre 3 : L'identification des risques



Où en sommes-nous ?

Approches descendante et ascendante

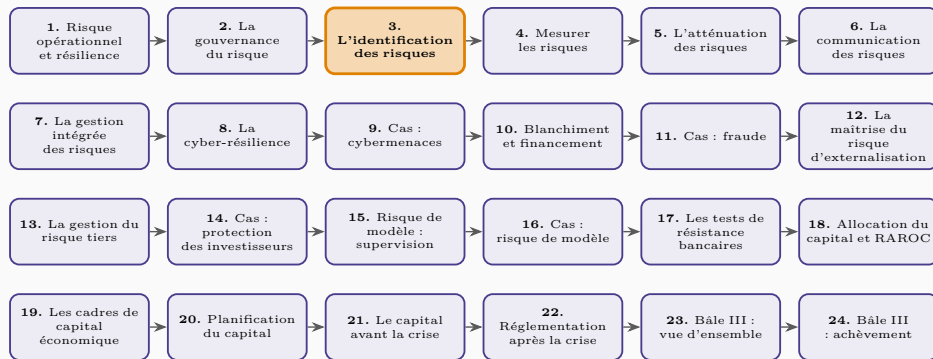
L'analyse de scénarios

La taxonomie du risque opérationnel

L'inventaire des risques opérationnels

Synthèse

Où en sommes-nous?



Pourquoi ce chapitre ?

L'identification est la première étape du cycle de gestion des risques : les risques ignorés, non anticipés ou mal compris sont, par construction, des risques non gérés. Ce chapitre présente les approches descendante et ascendante d'identification, les principaux outils utilisés en pratique, l'analyse de scénarios, et la taxonomie qui organise l'ensemble en un inventaire cohérent.

Approches descendante et ascendante

Top-down et bottom-up

L'identification **descendante** (top-down) part du conseil d'administration et de la direction générale pour repérer les menaces majeures susceptibles de compromettre les objectifs stratégiques de l'établissement. L'identification **ascendante** (bottom-up) part du terrain — départements, processus, activités — pour évaluer le risque opérationnel au plus près de son origine. Leur mise en regard, souvent appelée « réconciliation », est en réalité davantage une consolidation qu'une véritable réconciliation.

Une banque FinTech en forte croissance

Une approche descendante peut identifier le risque de cyberattaque comme une menace stratégique majeure pour une néobanque en forte croissance. L'approche ascendante, complémentaire, verra l'unité en charge des cartes de crédit aux petites entreprises évaluer spécifiquement la vulnérabilité de son système de candidature en ligne au piratage.

La roue des risques et le PESTLE

La « roue des risques » est un outil classique de brainstorming qui aide à visualiser les interconnexions entre thèmes de risque sous forme circulaire — utile pour repérer des chaînes de causes à effets, par exemple une pénurie de main-d'œuvre entraînant des retards de projets informatiques, qui eux-mêmes fragilisent la continuité d'activité. Le **PESTLE** (politique, économique, social, technologique, légal, environnemental) structure le balayage de l'horizon (« horizon scanning ») pour repérer les risques émergents.

Les sources externes de veille des risques émergents

Le Rapport sur les risques mondiaux du Forum économique mondial, l'enquête annuelle « Top Operational Risks » de risk.net, ou le rapport « Operational Risk Horizon » d'ORX sont des sources utiles d'inspiration, mais ne dispensent pas d'une identification propre à l'exposition et à la vulnérabilité spécifiques de chaque organisation.

RCSA, cartographie des processus, analyse des pertes

L'auto-évaluation des risques et des contrôles (RCSA) est un exercice mené en atelier, où les participants réfléchissent collectivement aux risques et contrôles de leur activité — méthode qui mêle en pratique identification et évaluation. La **cartographie des processus** consiste à décomposer un processus étape par étape et à se demander, à chaque étape, ce qui pourrait mal tourner. L'analyse des pertes internes et externes passées complète ce dispositif, notamment via les bases de données consortiales telles qu'ORX.

Les quasi-incidents sont des leçons gratuites

Un quasi-incident (« near miss ») est un événement qui aurait pu générer une perte opérationnelle mais qui, par chance ou grâce à un contrôle, ne l'a pas fait — par exemple une erreur de saisie rejetée pour une autre raison. Les quasi-incidents révèlent des vulnérabilités sans avoir causé de dommage réel; leur remontée n'est possible que dans un environnement de culture du risque sain, sans blâme injustifié, faute de quoi la tentation de les dissimuler — puisque rien n'est finalement arrivé — devient trop forte.

L'analyse de scénarios

Des événements rares par nature ou par construction

L'analyse de scénarios identifie des événements extrêmement dommageables, rares soit par nature (catastrophes naturelles, pandémies), soit par construction (cyberattaques majeures, rares parce que de nombreux contrôles devraient échouer simultanément pour qu'elles se produisent).

Génération, puis sélection

La phase de **génération** vise à produire une longue liste de scénarios possibles, lors d'ateliers animés par des professionnels du risque opérationnel, nourris par les pertes internes et externes, les résultats de RCSA, les indicateurs de risque et les problèmes d'audit. La phase de **sélection** consolide, élimine ou ajoute des scénarios pour aboutir à une liste pertinente — généralement 15 à 20 scénarios pour un établissement de taille moyenne, jusqu'à 50 pour une banque internationale.

Le vote silencieux, une technique pour éviter les biais de groupe

Le « vote silencieux » consiste à demander à chaque participant d'écrire ses préoccupations avant toute discussion orale, afin d'éviter qu'une personnalité dominante ou senior n'oriente prématurément la conversation. Chaque préoccupation est ensuite débattue une à une, garantissant une contribution équilibrée de tous les participants.

Deux biais fréquents à corriger

Le biais de **myopie** surestime les événements récents — les risques pandémiques, absents des registres de risques en 2019, étaient omniprésents en 2021. Le biais de **focalisation excessive sur les causes externes** conduit les organisations à privilégier des scénarios liés à des causes extérieures (pandémies, cyberattaques, catastrophes naturelles) alors qu'une part substantielle des pertes historiques majeures du secteur financier résulte en réalité de causes internes — trading non autorisé, manipulation de taux, manquements de conformité.

La taxonomie du risque opérationnel

Une distinction fondamentale

La bonne pratique du secteur financier consiste à catégoriser séparément les causes, les risques (événements), les impacts et les contrôles, puis à les relier entre eux lors de la phase d'évaluation. Cette distinction, bien qu'apparemment simple, est souvent une question de jugement : un même incident peut être décrit avec plusieurs causes et impacts possibles selon l'angle retenu.

Trois niveaux de détail

La taxonomie du BCBS distingue le niveau 1 (les sept catégories d'événements présentées au chapitre 1), le niveau 2 (subdivisions plus fines) et le niveau 3 (exemples illustratifs). Seuls les deux premiers niveaux constituent des catégories réglementaires officielles; le niveau 3 sert uniquement d'illustration. Cette taxonomie, définie à la fin des années 1990, reste la référence officielle plus de vingt ans plus tard.

Causes PPSE : personnes, processus, systèmes, événements externes

En 2019, ORX a publié, avec le concours d'Oliver Wyman, une taxonomie de référence des causes organisée selon les quatre catégories du sigle **PPSE** issu de la définition de Bâle : personnes, processus, systèmes, événements externes — chacune subdivisée en catégories de niveau 2 (compétence, gouvernance, conception des processus, disponibilité des systèmes, environnement politique et réglementaire, etc.).

Quatre catégories d'impacts

Le marché distingue désormais quatre catégories communes d'impacts du risque opérationnel : la perte financière, l'atteinte à la réputation, la non-conformité réglementaire, et le préjudice client. Pour les activités où la continuité de service est cruciale, la perturbation du service constitue une cinquième catégorie d'impact, appelée à se généraliser avec l'attention réglementaire croissante portée à la résilience.

Quatre types de contrôles

Les contrôles internes se classent en quatre catégories : les contrôles **préventifs** (réduisent la probabilité en agissant sur les causes), **détectifs** (identifient l'événement pendant ou après sa survenue), **correctifs** (réduisent l'impact d'un incident déjà survenu), et **directifs** (procédures, formations et lignes directrices qui structurent la conduite des opérations). Le chapitre 5 détaille ces contrôles.

L'inventaire des risques opérationnels

Plusieurs noms pour un même exercice de recensement

Le résultat de l'application d'une taxonomie aux risques propres à un établissement forme son **inventaire** ou **universe des risques** — la liste exhaustive des risques auxquels l'organisation estime être exposée. Le **registre des risques** en constitue le document de travail central, incluant généralement une évaluation de la probabilité et de l'impact résiduels. Les **risques émergents** sont ceux que l'organisation identifie comme naissants ou en hausse, encore mal compris ou pas encore pleinement intégrés à la taxonomie. Le **top-dix** des risques est la synthèse des combinaisons de probabilité et d'impact les plus significatives, rapportée au moins trimestriellement au comité exécutif.

Synthèse

Synthèse du chapitre

L'identification des risques combine une approche descendante, qui capte les menaces stratégiques majeures depuis le sommet de l'organisation, et une approche ascendante, qui capte les risques au plus près des processus grâce à la RCSA, la cartographie des processus et l'analyse des pertes passées et des quasi-incidents. L'analyse de scénarios prolonge cet exercice vers les événements rares et extrêmes, au prix d'une vigilance particulière contre les biais de myopie et de focalisation excessive sur les causes externes. L'ensemble se structure grâce à une taxonomie distinguant clairement causes (PPSE), risques, impacts et contrôles — la référence officielle restant la taxonomie de Bâle en trois niveaux, complétée par la taxonomie de référence d'ORX — pour aboutir à un inventaire des risques qui sert de socle à l'étape suivante : l'évaluation, objet du chapitre 4.